VULNERABILITATS EN XARXES

ÍNDEX

1. Introducció. TCP/IP
2. Protocol Ethernet
3. Protocol IP
4. Protocol ICMP
5. Protocol TCP
6. Protocol DNS

Introducció. TCP/IP

- TCP/IP es divideix en les 4 capes següents
  - **Capa de xarxa:**

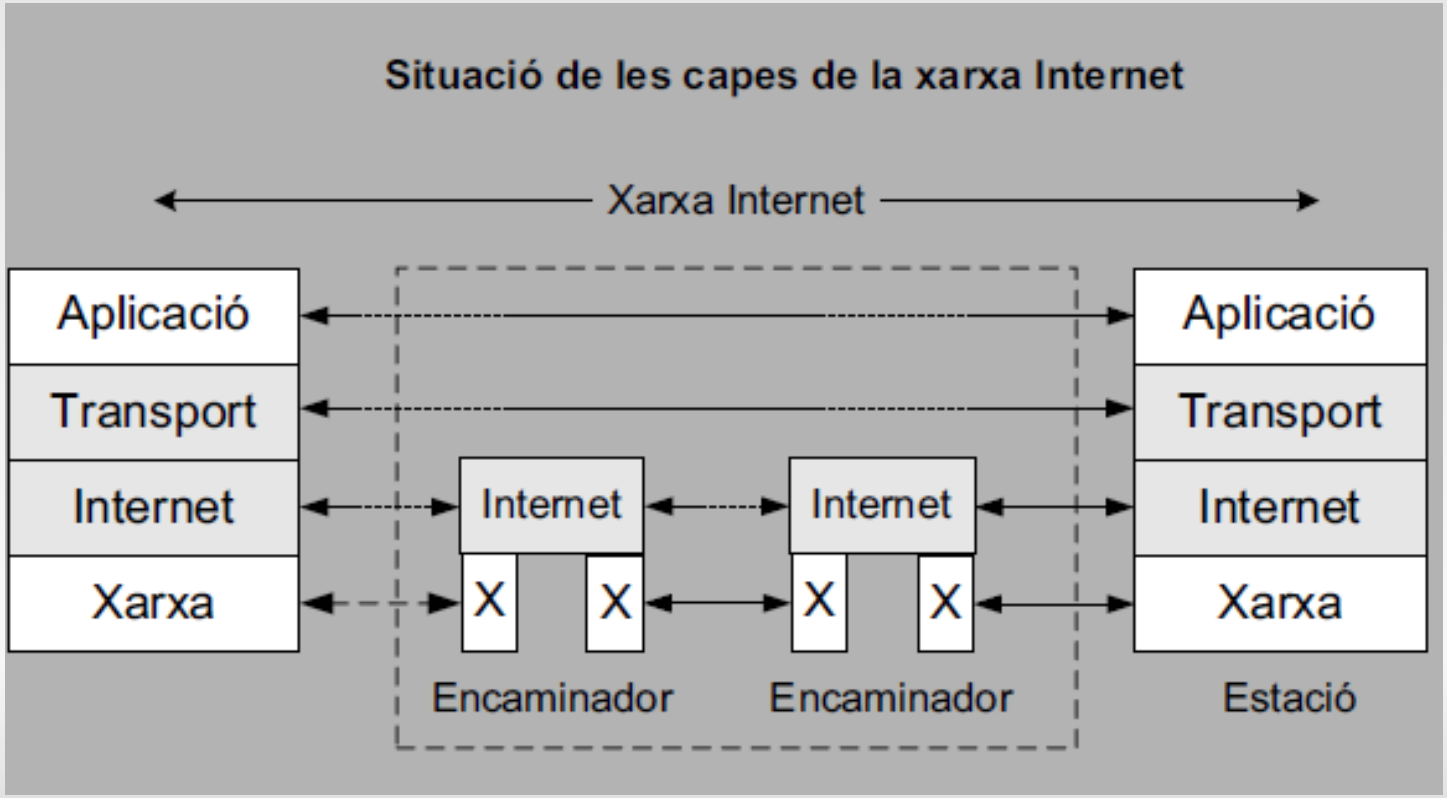
    També anomenada link layer o network access layer, engloba les connexions LAN i WAN.
  - **Capa d'Internet**

    Permet l'enviament de dades entre xarxes locals. Proporciona un sistema d'adreçament global (IP) l'encaminament de paquets de dades.
  - **Capa de transport**

    Control d'errors, segmentació, control de flux, control de congestió, i l'adreçament a la capa d'aplicació mitjançant l'ús de ports.
  - **Capa d'aplicació**

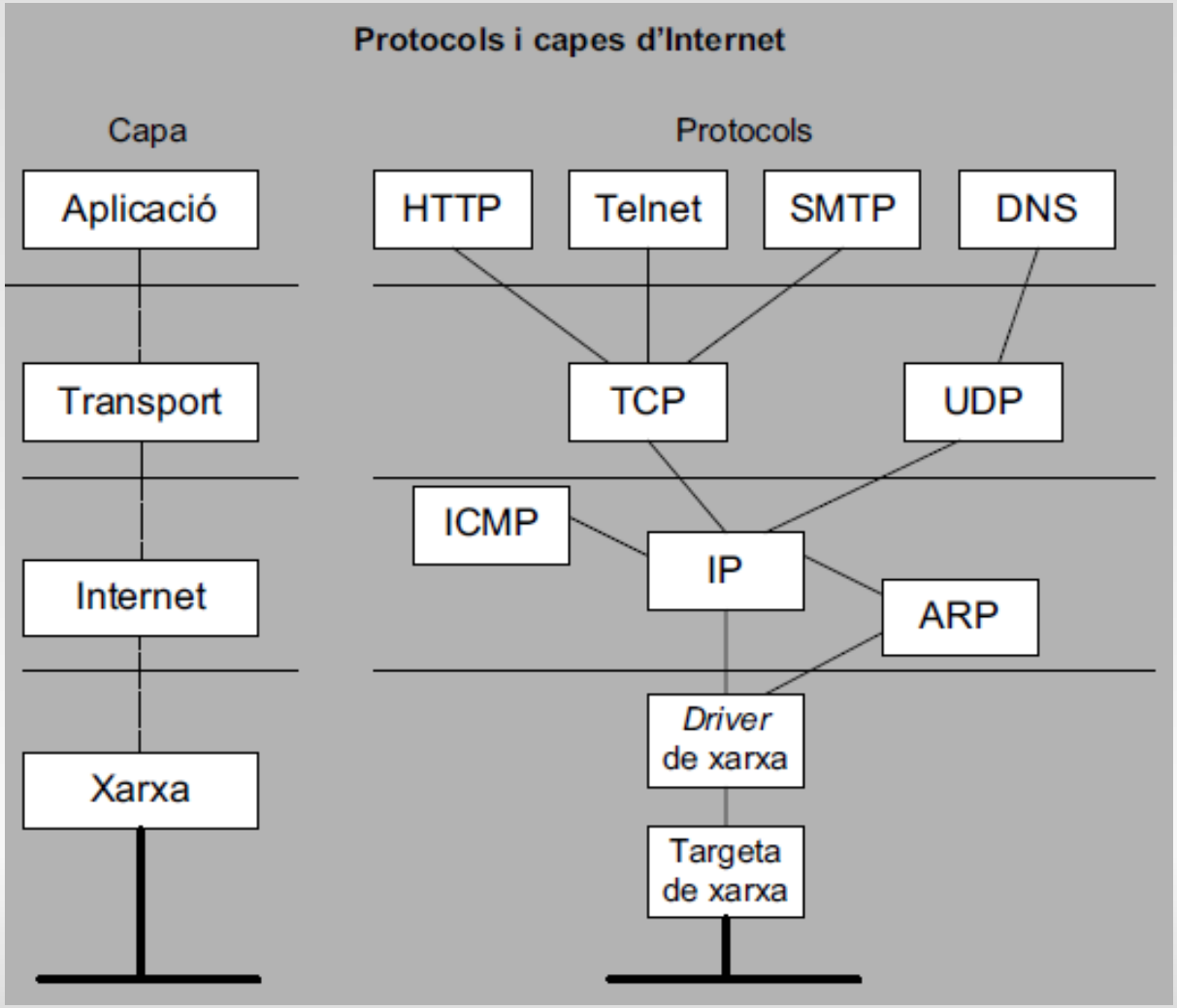
Introducció. TCP/IP

- Només els equips terminals implementen totes les capes. Els equips intermedis únicament implementen el nivell de xarxa i el nivell IP:



Introducció. TCP/IP

- A cadascuna de les capes exposades trobem protocols diferents:



Protocol Ethernet

- Hi ha molts protocols de xarxa d'àrea local o LAN. Les xarxes locals cablades més utilitzades són les basades en Ethernet:
  - Ethernet utilitza **adreces físiques o MAC de 48 bits** úniques globalment i assignades pel fabricant.
  - Utilitza paquets denominats **trames de 1.518 bytes** amb un espai per a 1.500 bytes de dades.
  - Quan una xarxa Ethernet es connecta a una altra xarxa (o a Internet) mitjançant TCP/IP és necessari **"traduir" adreces físiques a adreces IP**. Aquesta traducció es du a terme mitjançant el protocol ARP
  - TRAMA ETHERNET

Protocol Ethernet - Sniffers

- **La facilitat de detectar trànsit local.** Ethernet utilitzava una topologia de bus en què tots els paquets s'enviaven al bus i solament l'ordinador amb l'adreça de destinació del paquet el recollia.
  - En les targetes de xarxa Ethernet hi ha un mode de **funcionament promiscu** (promiscuous mode) que permet recollir tots els paquets que passen pel bus.
  - Aquest mode de funcionament està pensat per a monitorar la xarxa en la detecció de problemes i **permet l'ús de la targeta com a pont (bridge)** per a la virtualització de maquinari
  - Tcpdump, wireshark, ettercap ...

Protocol Ethernet - Sniffers

- Ethernet a evolucionat de topologies en bus amb concentradors a topologies segmentades amb **commutadors** (té la capacitat d'aprendre la topologia de la xarxa).
  - Per tant, **impossibilita que un ordinador en mode promiscu pugui rebre tots els paquets que circulen per la xarxa**.
  - Tot i això hi ha **vulnerabilitats** inherents als actuals commutadors Ethernet que permeten **convertir un commutador en un concentrador.**

Protocol Ethernet

MAC FLOODING

- Un Switch manté **una taula anomenada CAM** (content addressable memory), on estableix un **vincle entre adreces MAC i ports físics** del commutador mateix.
- Aquesta taula permet al commutador **enviar els paquets únicament al seu destinatari pel port físic corresponent.**

Protocol Ethernet

MAC FLOODING

- **La taula CAM té una memòria limitada,** per tant, un atacant pot saturar aquesta taula amb el propòsit de deixar-la inutilitzada.
- Per a això, **bombardeja el commutador amb paquets Ethernet amb adreces MAC d'orígens diferents**, la qual cosa provoca que el commutador les afegeixi a la taula CAM fins que aquesta s'esgota.
- **Quan el Switch no pot afegir més entrades comença a actuar com un Hub.**

Protocol Ethernet

MODIFICACIÓ ADRECES MAC

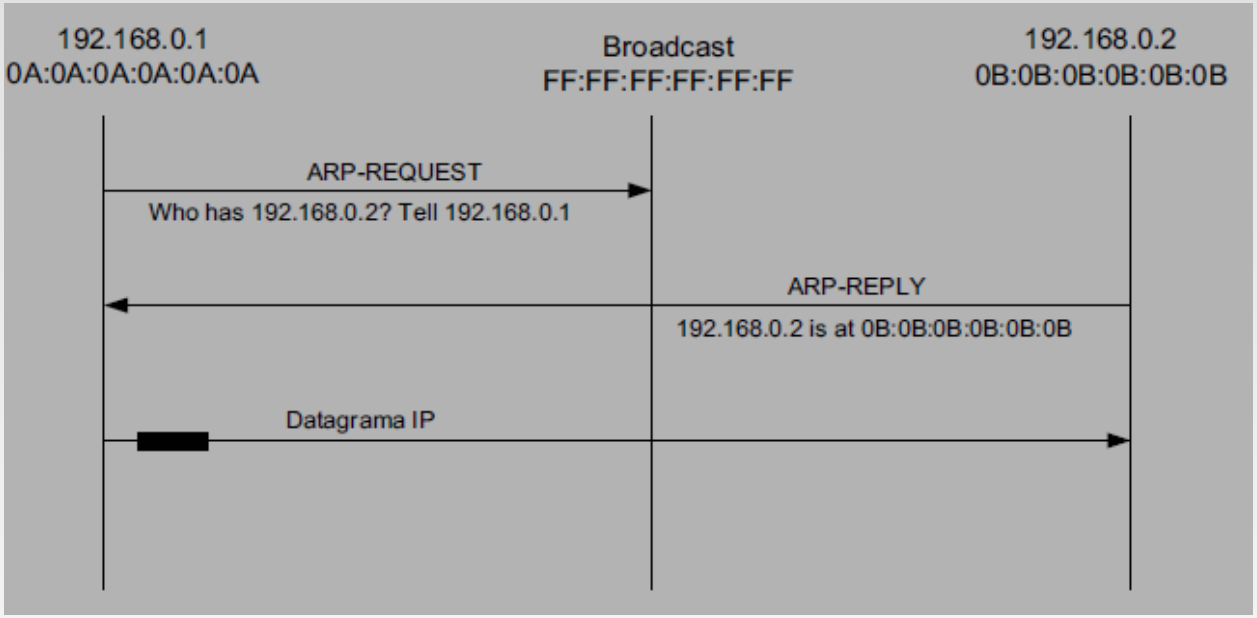
- L'actual facilitat per a canviar adreces físiques representa una vulnerabilitat important en **sistemes de control d'accés o autenticació de xarxa basats en aquestes adreces.**

ifconfig eth0 hw ether 00:11:22:33:44:55

Protocol Ethernet - ARP

VULNERABILITATS PROTOCOL ARP

- El protocol ARP permet traduir adreces MAC en adreces IP.



- Per a evitar estar fent peticions ARP contínuament, cada ordinador manté una taula amb les correspondències entre adreça física i adreça IP anomenada **memòria cau ARP**

Protocol Ethernet - ARP

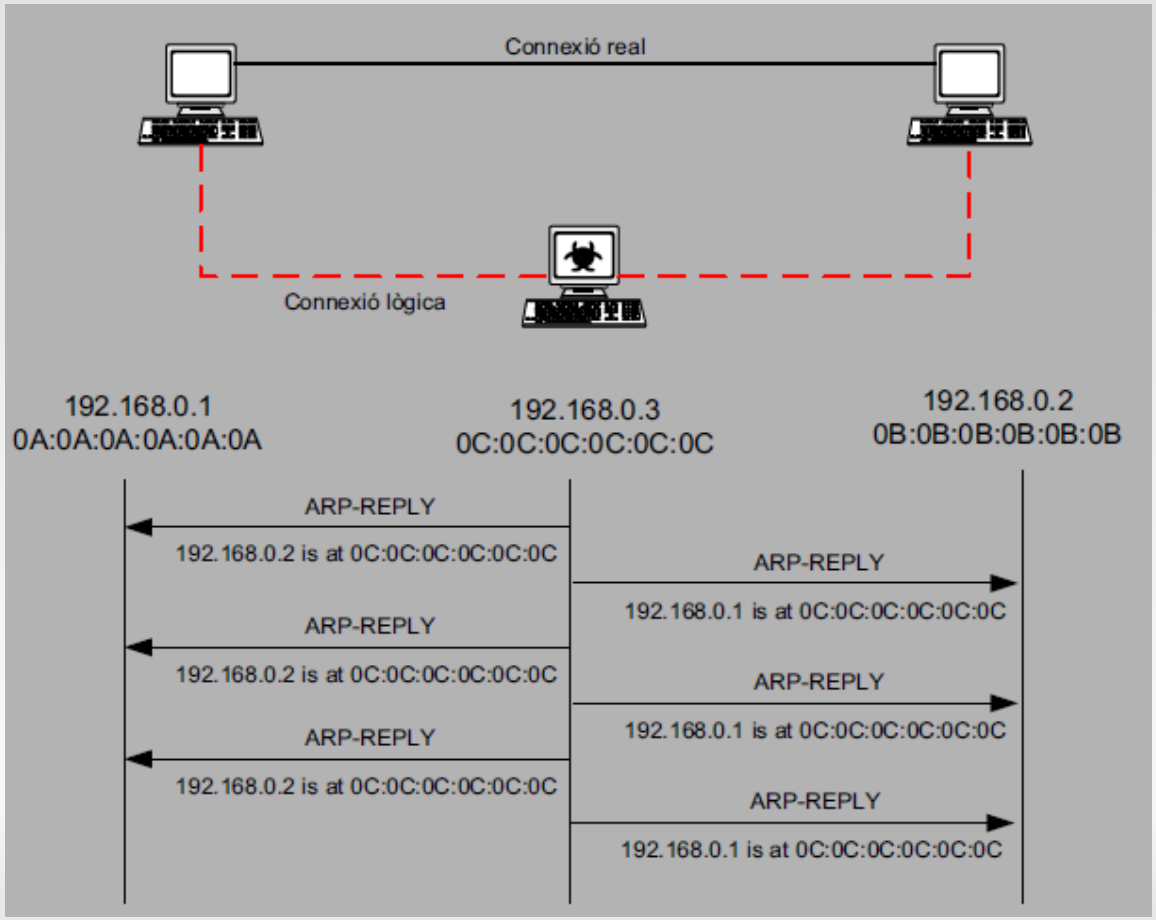
- **ARP Spoffing/Poisioning/Flooding**
  - **Denegació de servei**: es pot aconseguir que un ordinador no rebi cap paquet en difondre una adreça física inexistent associada a la seva adreça IP real. Si la víctima de la denegació de servei és l'encaminador o porta d'enllaç de la xarxa local, s'aconsegueix aïllar la xarxa local de l'exterior.
  - **Man in the middle (MITM)**: un atacant es pot fer passar per un altre ordinador (víctima) i rebre així tots els paquets destinats a aquesta víctima.

Recursos

- http://www.oxid.it/downloads/apr-intro.swf
- http://www.youtube.com/watch?v=xI9Iq9gte2o#!

Protocol Ethernet - ARP

- **ARP Spoffing/Poisioning/Flooding**
  - Man in the middle (MITM)



Protocol IP

IP spoofing

- Consisteix a generar paquets IP amb l'adreça d'origen falsa. Aquesta vulnerabilitat se sol explotar amb l'objectiu de fer **atacs de denegació de servei o suplantar un ordinador concret**.

Packet-of-death

- L'enviament de paquets IP deliberadament erronis pot causar problemes importants en algunes implementacions**. Un exemple és l'ús de la mateixa adreça IP com a origen i destinació (land attack).**

Protocol IP

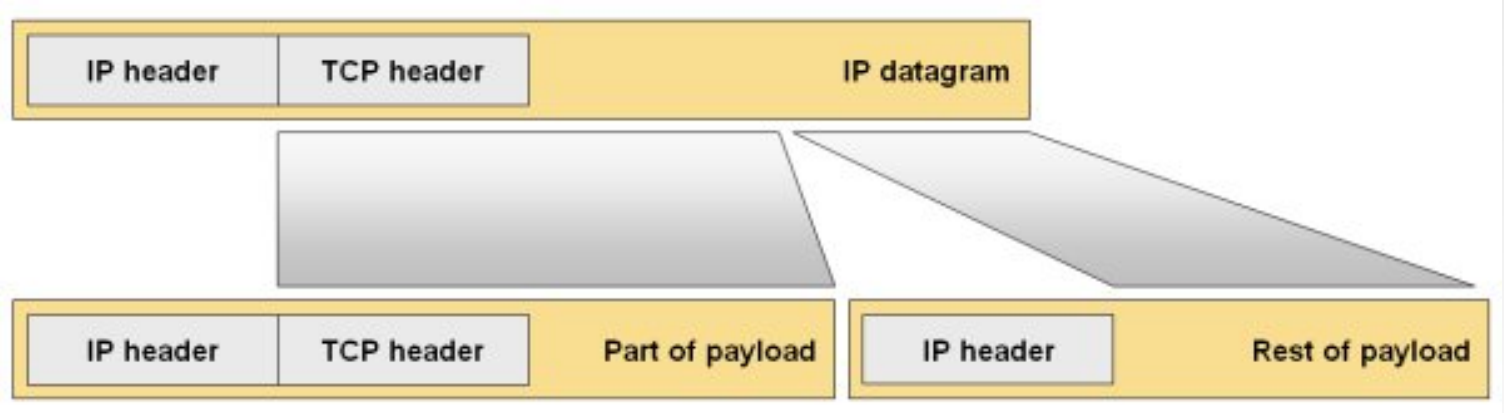
Vulnerabilitats en la Fragmentació IP

- **IP pot fer fragmentació de paquets per a adaptar-se a les mides de paquets de xarxes locals (MTU).**
- **Un atacant** tractarà de provocar una **fragmentació intencionadament** en els datagrames que envia cap a la nostra xarxa per tal que passin desapercebuts per diferents dispositius de prevenció i de detecció d'atacs que no tenen implementat el **procés de fragmentació i reassemblatge de datagrames IP**.
- També permet realitzar **atacs de denegació de servei** com és el conegut ***teardrop attack***.

Protocol IP

Vulnerabilitats en la Fragmentació IP

- La capçalera TCP només es clona al primer paquet.
- La capçalera IP es clona a tots el paquets.



Protocol IP

Vulnerabilitats en la Fragmentació IP

- En els dispositius de prevenció més bàsics, per a bloquejar paquets **es basen generalment en la informació de capçalera dels paquets** (com per exemple, ports TCP o UDP de destinació).
- Per solucionar l'ús de la fragmentació fraudulenta i garantir una inspecció de paquets correcta, **és necessari implementar el procés de fragmentació i reassemblatge de datagrames en dispositius de prevenció i detecció (firewall)**.

Protocol ICMP

- El protocol ICMP (Internet control message protocol) **és un protocol de control i notificació d'errors del protocol IP** que ha presentat algunes vulnerabilitats importants, generalment associades a **atacs de denegació de servei.**
  - **Ping flooding**
  - **Ping of death**
  - **Smurf attack**

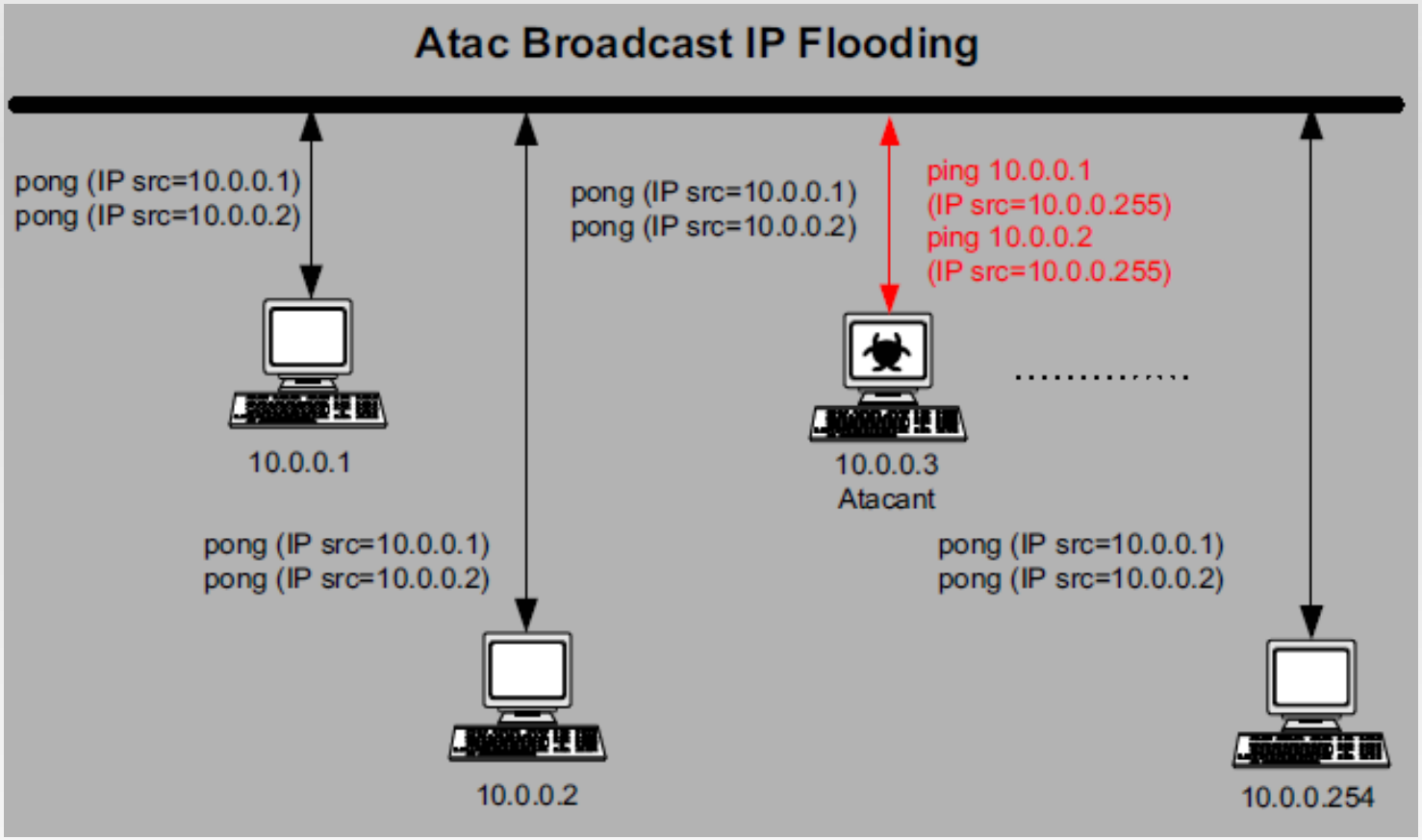
Protocol ICMP

PING FLOODING (IP Flooding)

- Aquest atac es realitza habitualment en xarxes locals o en connexions amb una gran amplada de banda. Consisteix en la generació de trànsit d'escombreries amb l'objectiu d'aconseguir la degradació del servei. **En el cas del Ping Flooding son paquets IP de tipus ICMP**, també podrien ser TCP o UDP.
- Es pot amplificar l'atac utilitzant adreces de broadcast.

Protocol ICMP

PING FLOODING (IP Flooding)



- S'envien peticions echo-request de ICMP a diversos ordinadors falsejant l'adreça IP d'origen, substituïda per l'adreça de broadcast de la xarxa a atacar. D'aquesta forma, totes les respostes individuals es veuen amplificades i propagades a tots els ordinadors connectats a la xarxa

Protocol ICMP

PING OF DEATH

- Atac d'interès històric que va afectar gairebé totes les implementacions d'ICMP fins al final dels noranta. **Consisteix a enviar un paquet ICMP de més grandària que el màxim permès per IP fragmentat (65535 bytes)**. Això provocava un desbordament de memòria intermèdia en l'ordinador de destinació.

ping 192.168.1.100 -s 65510

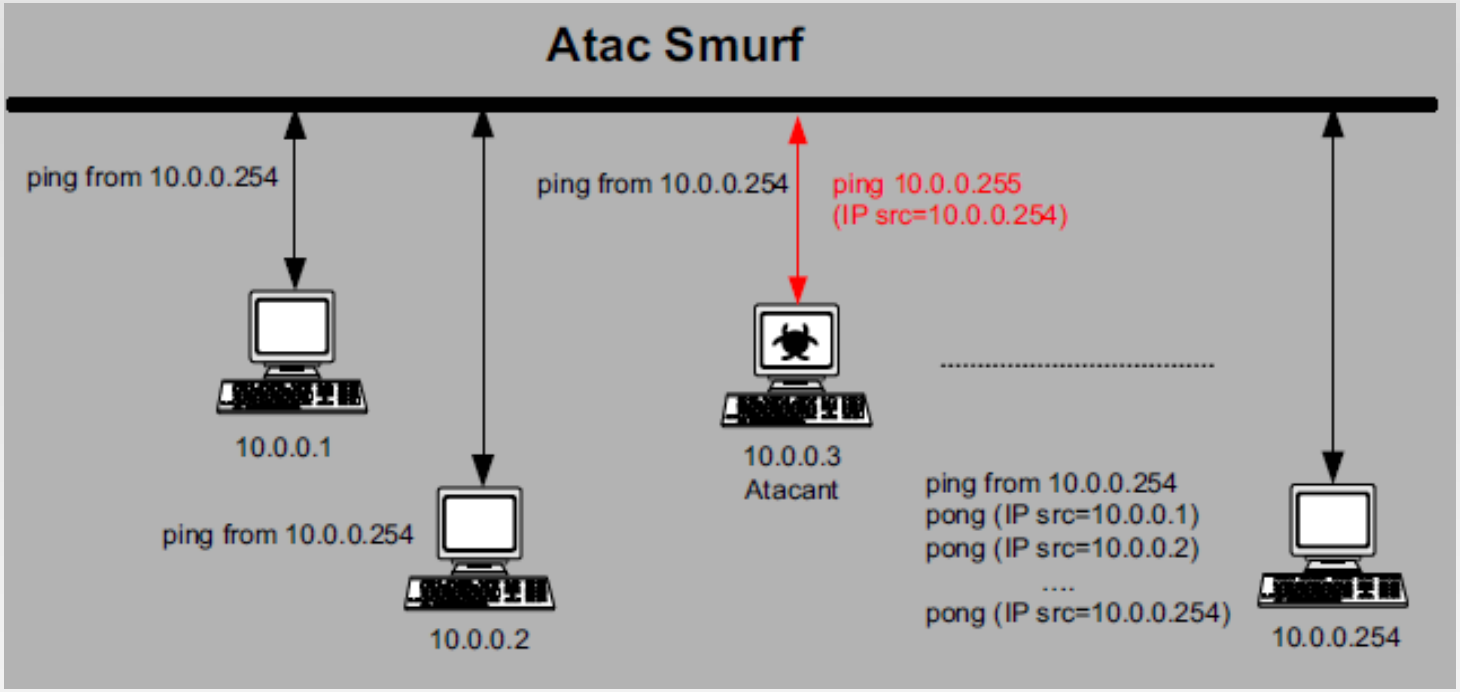
Protocol ICMP

SMURF ATTACK

- Atac de denegació de servei en el qual l'atacant envia missatges de ping en difusió (broadcast) amb l'adreça d'origen de la víctima.
- Això provoca que tots els ordinadors que reben el paquet enviïn la resposta del ping a la víctima.

Protocol ICMP

SMURF ATTACK



- Com a adreça d'origen es posa l'adreça IP de la màquina que ha de ser atacada. En el camp de l'adreça IP de destinació es posa la l'adreça de difusió de la xarxa local o xarxa que s'utilitzarà com a trampolí per col.lapsar la víctima.

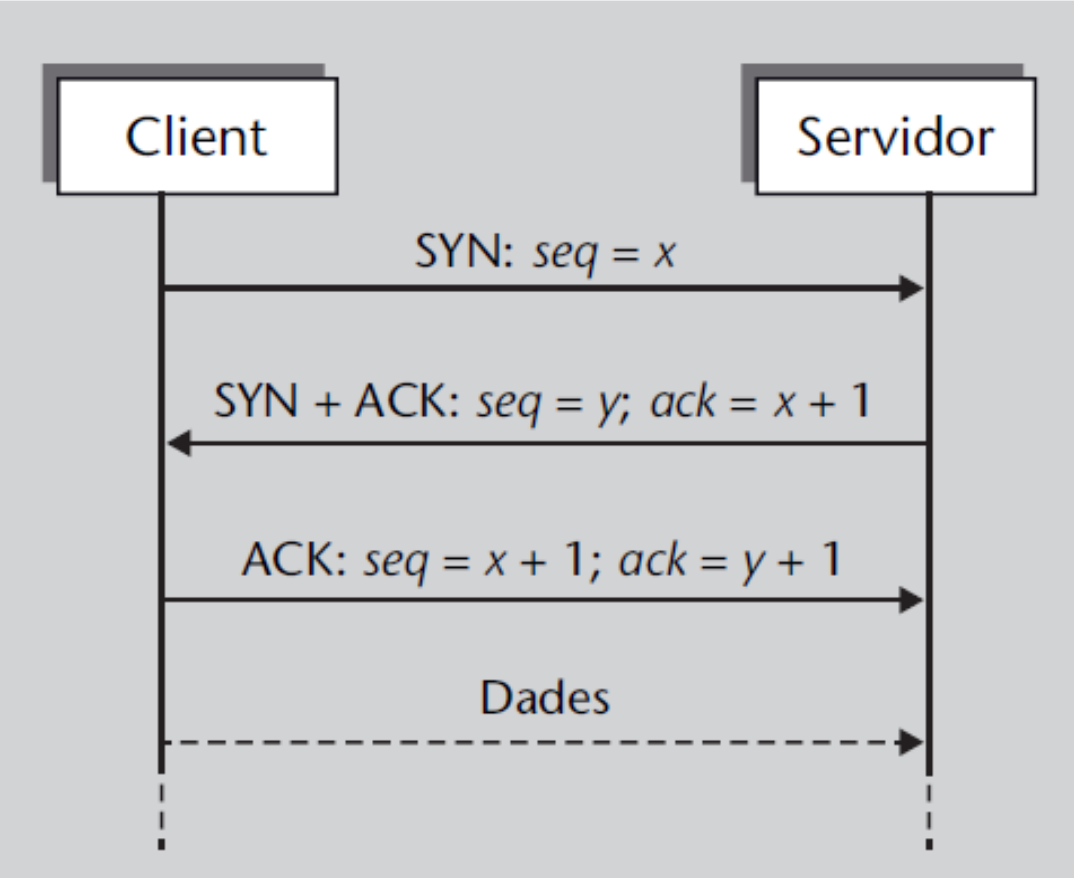
Protocol TCP

- **TCP proporciona un servei genèric de transmissió fiable de dades d'extrem a extrem.** S'encarrega de controlar errors en la transmissió, l'ordre dels paquets, la detecció de duplicats, el control de velocitat de transmissió, etc.
- TCP és un protocol **orientat a connexió.** S'estableix una connexió entre els dos extrems que es manté durant la transmissió de dades. Aquesta connexió es crea mitjançant el denominat **3-way handshake**.

Protocol TCP

- **La connexió s'estableix amb tres missatges**:
  - un missatge de tipus SYN (de sincronització),
  - Que el servidor contesta amb un SYN i ACK (sincronització i reconeixement);
  - Finalment el client envia un ACK (reconeixement).
- Una vegada establerta la connexió, el client i el servidor es poden enviar dades.

Protocol TCP



- Els números de seqüència de client i servidor s'utilitzen per a identificar els bytes de dades enviats i permeten fer una gestió del flux de dades: control de l'ordre d'enviament, pèrdua, duplicats. El número d'ack confirma la recepció correcta de tots els missatges amb número de seqüència igual o inferior

Protocol TCP – SYN FLOODING

- En l'establiment de sessió, quan el client envia el missatge SYN, el servidor contesta (SYN+ACK) i es queda esperant l'ACK del client.
  - **Què succeeix si el client no envia aquest ACK?** Com cal esperar, el servidor espera un temps prudencial, i si no rep l'ACK dóna la connexió per perduda

- **Això permet muntar una atac DoS.**
  - La idea és bombardejar un servidor amb peticions de connexió i no fer l'últim ACK. D'aquesta manera, el servidor **es queda amb connexions mig establertes** que consumeixen, durant un temps determinat, recursos del servidor

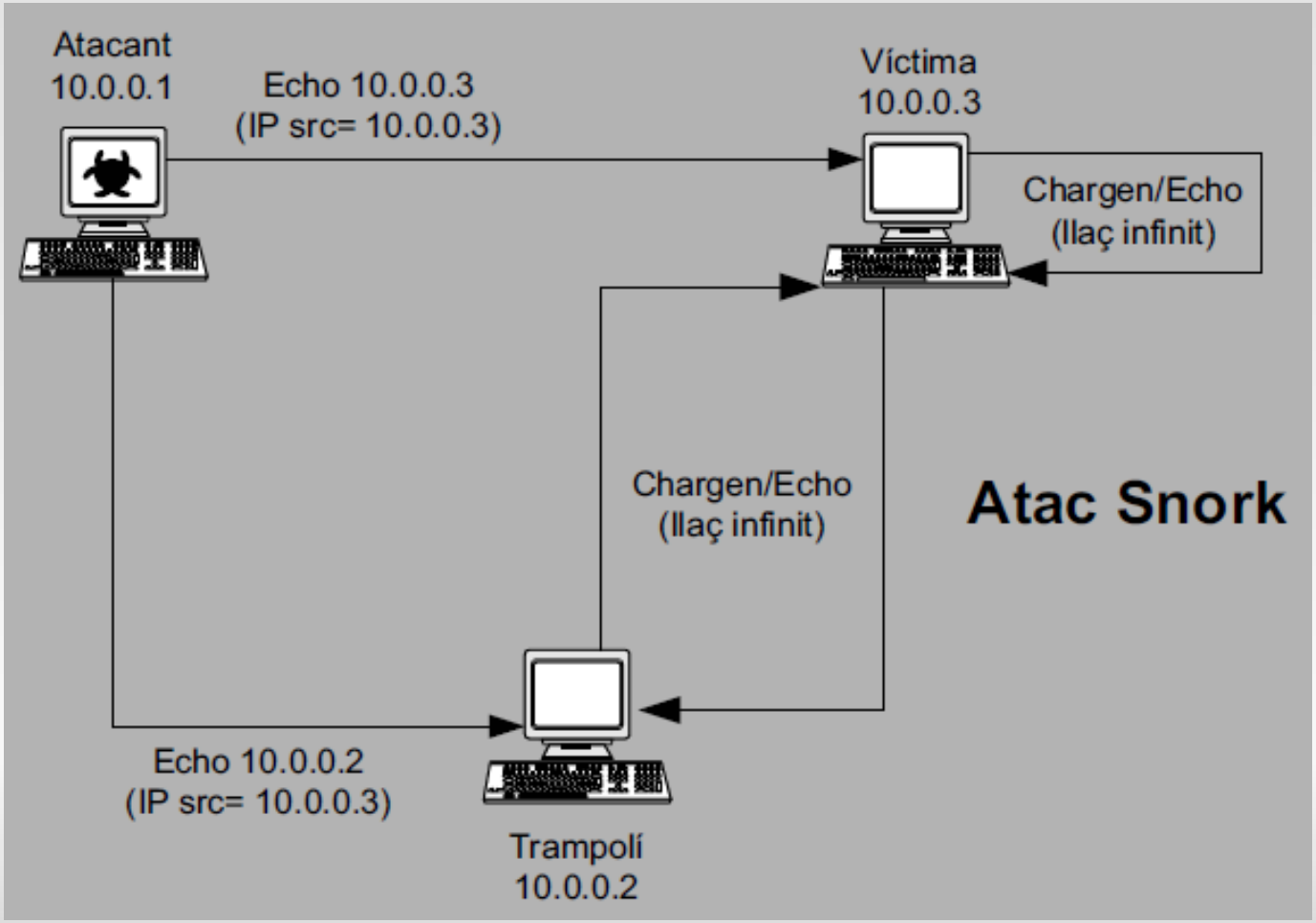
Protocol TCP – Segrest sessions

- La possibilitat de predicció de números de seqüència va resultar ser una vulnerabilitat important de TCP; avui dia les implementacions de TCP posen molt interès a generar els números de seqüència de la manera més aleatòria possible per a evitar aquest tipus de problemes.
- **Els atacs de segrest** s'aprofiten de la poca exigència en el protocol d'intercanvi de TCP respecte a l'autenticació dels equips involucrats en una sessió TCP.

http://www.linuxfocus.org/Castellano/March2003/article282.shtml#282lfindex4

Protocol TCP – SNORK

- Consisteix en el **creuament dels serveis ECHO i CHARGEN,** mitjançant l'enviament d'una petició falsa al servei CHARGEN, havent col.locat com a adreça d'origen l'adreça IP de la màquina a atacar (amb el port del servei ECHO com a port de resposta)



Atacs distribuïts – Botnets

- Un atac de denegació de servei distribuït és aquell en el qual una multitud de sistemes (que prèviament han estat compromesos) cooperen entre ells per atacar un equip objectiu i li causen una denegació de servei.
- El flux de missatges d'entrada que pateix l'equip atacat el deixarà sense recursos i serà incapaç d'oferir els seus serveis als usuaris legítims.
- **TRIN 00**

  http://en.wikipedia.org/wiki/Trinoo

Protocol DNS

- **DNS spoofing**

  Consisteix a donar informació errònia demanera deliberada sobre la correspondència d'adreça IP a nom de domini. L'objectiu pot ser per exemple associar una IP "falsa" a un nom de domini conegut (amb la qual cosa es pot redirigir el trànsit a aquest domini).

- **DNS cache poisoning**

  Per a millorar l'eficiència de DNS cada servidor manté una memòria cau amb les últimes resolucions fetes. Igual que en el cas d'ARP, es pot forçar l'entrada de relacions de nom de domini a adreça IP falsa en aquesta memòria cau.

- **DNS amplification attacks**

  Són uns atacs de denegació de servei que exploten el fet que les peticions de DNS es resolen recursivament